INSPECCO × KRIPTARIUM

Safety 4.0 Bootcamp

Laboratuvar Föyleri — MOSTRO 1000 Kalibre Zımpara Makinesi

Tüm laboratuvarlar gün boyu gelişen tek bir örnek makine — MOSTRO 1000 kalibre zımpara makinesi — üzerinde işlenir.

LAB 1 · Safety Architecture	Çıktı: Safety Function Map
LAB 2 · IEC 62443 Mini Workshop	Çıktı: Zone / Conduit Diagram
LAB 3 · Threat & Risk + Risk Matrix	Çıktı: Risk Register
LAB 4 · Secure Remote Access	Çıktı: Secure Architecture
LAB 5 · SBOM / CVE / Patch	Çıktı: Vulnerability Decision
LAB 6 · CRA Incident Simulation	Çıktı: Incident Workflow
LAB 7 · AI Safety Challenge	Çıktı: AI Fail-Safe Decision

Bu föyler bir eğitim çıktısıdır; resmî denetim, uygunluk değerlendirmesi veya belgelendirme değildir ve CE/mevzuat uygunluğu garantisi vermez. Doldurduğunuz föyler gün sonunda Machine Starter Pack'inizi oluşturur ve Safety 4.0 Workspace'te yaşamaya devam eder.

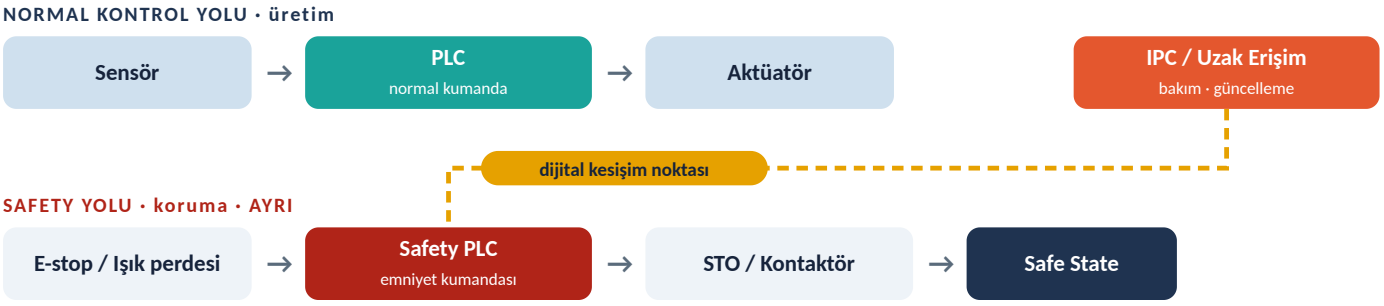
LABORATUVAR 1 · MOSTRO 1000 · Kalibre Zımpara

Safety Architecture

Çıktı: Safety Function Map

Ad Soyad | Grup | Tarih

Kavram: Emniyet fonksiyonu, insanı koruyan fonksiyondur ve **ayrı bir safety yolunda** yaşar (E-stop → Safety PLC → STO). Gerekli güvenilirliği (PLr/SIL) riskle orantılıdır — ve bu güvenilirlik, **dijital bir konfigürasyona** bağlıdır.



Görev — sırayla cevaplayın

1 Bu makinede tehlike nedir? İnsan neyden zarar görür?

Hasar: sıcak çene yanığı/ezilme, bant ve silindir çekilmesi, besleme sıkışması, bant kopması fırlaması, toz (solunum) ve yangın. Koruma açıkken parmak bant/silindire girer.

2 Safety function (emniyet fonksiyonu) hangisidir?

Koruyucu kapak açıldığında veya ışık perdesi ihlal edildiğinde tehlikeli hareketin (bant, besleme silindirleri) güvenli durdurulması (STO), acil durdurma dahil.

3 Safety-related control system nerede? Şemada işaretleyin.

Güvenlik rölesi/Safety PLC; kapak kilitli güvenlik anahtarları, ışık perdesi, acil durdurma → STO (sürücü) veya kontaktör. Şemada SAFETY YOLU kutularıdır.

4 Normal PLC ile Safety PLC farkı nedir?

Normal PLC üretimi (hız, ölçü, besleme) yönetir. Safety PLC/güvenlik rölesi koruyucu fonksiyonu çift kanallı, kendini teşhis eden, sertifikalı yapıda yürütür.

5 PLr / SIL neden var? Bu fonksiyon için neden önemli?

PLr → PL: çekilme riski yüksek olduğu için bant/silindir koruması PL d/e hedefler. Risk grafiği ile belirlenir ve kayda geçer.

6 Safe state (güvenli durum) nedir?

Safe state: bant ve silindirlerin durduğu, enerjinin güvenli kesildiği, yeniden başlatma kilidinin devrede olduğu durum.

7 Safety function hangi dijital bağımlılıklara sahip?

Sürücü parametreleri (hız/akım sınırı), güvenlik rölesi konfigürasyonu, HMI ayarları, güncelleme kanalı, varsa uzak izleme modülü.

8 Siber müdahale hangi noktadan bu fonksiyonu bozar?

Uzaktan izleme/parametre yazma kanalı ve servis hesabı. Parametre değişirse kapak kilidi veya kalınlık sınırı bypass edilebilir.

Bu föyün çıktısı **Safety Function Map** → Evidence Pack **EP 03 Safety Functions** başlığına oturur.

LABORATUVAR 2 · MOSTRO 1000 · Kalibre Zımpara

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad | Grup | Tarih

Kavram: Zone = benzer kritiklikteki cihazları bir bölgeye topla. **Conduit** = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz — mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi

PLC · HMI · Robot kontrolörü · **Safety PLC** · SCADA istemcisi · Mühendislik istasyonu · Uzak servis erişimi · Ofis ağı (ERP/e-posta)

1 Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

Zone 1 Güvenlik (güvenlik rölesi/Safety PLC, kapak kilitleri, ışık perdesi, acil durdurma); Zone 2 Kontrol (PLC, HMI, sürücüler); Zone 3 DMZ (uzak servis); Zone 4 Kurumsal. 'admin/admin' ve kilitsiz USB kabul edilemez.

2 Safety PLC'yi hangi bölgeye koydunuz — neden?

Uzak servis modülü Zone 3'e (DMZ) alınmalı. Zone 1 ve Zone 2'ye doğrudan bağlanmamalı. Bugünkü internete açık yerleşim kabul edilemez.

3 Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?

Zone 3→2: jump server, MFA, sınırlı protokol. Zone 2→1: yalnızca okuma veya veri diyotu, yazma yolu yok. Her geçişte kimlik, protokol filtresi, kayıt ve varsayılan kapalı.

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	Jump server: tek ve izlenebilir giriş
Tünel?	Açık / VPN	Sertifika tabanlı VPN, yalnızca gerekli adresler
Kimlik?	Parola / MFA	MFA: parola tek başına yetersiz
Hesap?	Paylaşılan / Kişisel	Kişisel hesap: sorumluluk ve iz için
Kayıt?	Yok / Tam oturum kaydı	Tam oturum kaydı: olay anında kanıt
Zamanlama?	Sürekli açık / Varsayılan kapalı	Varsayılan kapalı: yalnızca onaylı bakım penceresi

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.

LABORATUVAR 3 · MOSTRO 1000 · Kalibre Zımpara

Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad | Grup | Tarih

Kavram: Senaryo beş parçadır: **kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç**. Skor = L × S × E (her biri 1–3). **Kural:** S=3 ise skor düşük olsa bile senaryo öne alınır — insana zarar görünür kalır.

Görev — üç senaryo kurun ve puanlayın

Senaryo (kim→kapı→zincir→fiziksel sonuç)	L	S	E	Skor	Öncelik
1. Uzak servis + admin/admin → sürücü/güvenlik parametresi değişimi → kapak kilidi bypass → el çekilmesi	3	3	2	18	Kritik
2. HMI'den yanlış kalınlık/besleme ayarı → parça geri tepmesi → besleme sıkışması, ezilme	2	2	3	12	Yüksek
3. Toz emme interlock'u devre dışı → toz birikimi → yangın / solunum	1	2	3	6	Orta

Kritik 18–27 | Yüksek 9–17 | Orta 4–8 | Düşük 1–3

1. En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?

En yüksek öncelik: Senaryo 1 (L3·S3·E2 = 18, Kritik). Parametre bypass'ı ile çekilme riski doğrudan operatöre yansır, sonuç geri alınamaz.

2. S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?

Senaryo 3: S=3 (yangın/solunum) ama olasılık düşük olduğundan skor 6 (Orta) çıkar. Risk kaydında ayrı satır olarak izlenmeli, emme interlock'u izlenir.

Altın kural: Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir — bir adım daha gidin: bu, hattaki insana ne yapar?

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.

LABORATUVAR 4 · MOSTRO 1000 · Kalibre Zımpara

Secure Remote Access

Çıktı: Secure Architecture

Ad Soyad | Grup | Tarih

Kavram: İki katman, ikisi de şart: **erişim güvenliği** (girişi zorlaştır: ara nokta, VPN, MFA, kişisel hesap, kayıt, varsayılan kapalı) + **emniyet bağımsızlığı** (girse bile insan korunur).

Görev A — mevcut → hedef

MEVCUT (çizin/yazın)

Uzak servis modülü internete doğrudan açık; admin/admin; HMI aynı ağda; paylaşılan hesap; kayıt yok; sürekli açık.

HEDEF (beş ilkeyle yeniden tasarlayın)

1) Jump server 2) MFA + sertifikalı VPN 3) Kişisel hesap, en az yetki, güvenlik parametresi ayrı onay 4) Tam kayıt 5) Varsayılan kapalı

Görev B — functional safety köprüsü

1 Saldırgan tüm önlemlere rağmen içeri girerse: emniyet fonksiyonu etkilenir mi? Neden?

Mimari doğru değilse evet: saldırgan koruma parametrelerini değiştirir ve kapak kilidini bypass eder. Doğru tasarımda güvenlik fonksiyonu ağdan bağımsız, fiziksel anahtar/yetki ile korunur ve güvenli duruma geçer.

2 Emniyet fonksiyonunun kontrol sisteminden bağımsız çalışması için GEREKSİNİMİ yazın (çözümü değil).

Kapak kilidi, acil durdurma ve bant/besleme durdurma davranışı uzak servis ve kontrol ağından bağımsız olmalı. Güvenlik parametreleri fiziksel yetki ve ayrı doğrulama gerektirmelidir.

Tarafsızlık notu: Bu föy çözüm tasarlatmaz; gereksinimi tanımlatır. Tasarım kararı firmanızındır.

Bu föyün çıktısı **Secure Architecture** → Evidence Pack **EP 02 + EP 06** başlığına oturur.

LABORATUVAR 5 · MOSTRO 1000 · Kalibre Zımpara

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad | Grup | Tarih

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

SBOM'da bileşen (sürücü/PLC firmware) var mı; sürüm 2.4 etkilenen aralıkta mı; açık uzak erişimle ulaşılabilir mi. Üçü sağlanıyorsa etkileniyoruz.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

Makineyi durdurmak zorunlu değil; ancak uzak erişimi hemen kapatıp izole etmek zorunlu. Üretim, risk değerlendirmesi ve güvenli durum kontrolüyle karara bağlanır.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

Önce staging/HIL ortamında test. Test ve onay olmadan üretime yama uygulanmaz.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

Evet. Firmware değişimi kapak kilidi ve acil durdurma fonksiyonlarını etkiler; bu fonksiyonlar yeniden doğrulanır, PL hedefi kanıtlanır.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

Uzak erişimi kapatma, ağ segmentasyonu, izleme, varsayılan parolaların değiştirilmesi, firmware imza doğrulaması, bakım yetkisinin sınırlandırılması. Her önlemin etkisi test edilir.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.

LABORATUVAR 6 · MOSTRO 1000 · Kalibre Zımpara

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad | Grup | Tarih

Senaryo: Saat **10:15**. Servis hesabında yetkisiz erişim tespit edildi. PLC konfigürasyonu değişmiş olabilir. Makine hâlâ çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1. **10:15 — ilk 15 dk:** Kimi ararsınız? İlk üç eyleminiz?

Kimi ararsınız: vardiya sorumlusu, emniyet sorumlusu, BT/OT güvenlik, üretim müdürü. İlk üç eylem: bandı ve silindirleri güvenli duruma al, servis hesabını askıya al, kanıtı kopyala (resetleme yok).

2. **İlk 2 saat:** Emniyet güvende mi? Neyi korursunuz (kanıt!)? Hangi hesap kapatılır?

Emniyet: kapak kilidi, ışık perdesi ve acil durdurma testi; güvenlik rölesi/sürücü konfigürasyonu known-good ile karşılaştırılır. Kanıt: loglar, konfigürasyon yedeği/hash, kimlik kayıtları. Kapatılacak hesap: servis hesabı.

3. **24 saat — CRA erken uyarı:** Hangi bilgi hazır olmalı?

Etkilenen makine ve sürüm, tespit zamanı, şüpheli istismar, muhtemel etki (el-kol yaralanması), alınan ara önlemler.

4. **72 saat — CRA bildirim:** Kök neden, etki, önlem — kim ne yapıyor?

Kök neden (varsayılan parola, açık uzak erişim), etki, düzeltici önlemler, kullanıcı bilgilendirmesi. Her görev bir sorumluya atanmış.

5. **14 gün — son rapor:** Hangi loglar/kayıtlar korunmuş olmalı?

Tüm olay logları, sürücü/güvenlik rölesi konfigürasyon karşılaştırmaları, erişim kayıtları, yama ve doğrulama kayıtları, kararların gerekçeleri, ders çıkarımları.

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.

LABORATUVAR 7 · MOSTRO 1000 · Kalibre Zımpara

AI Safety Challenge

Çıktı: AI Fail-Safe Decision

Ad Soyad | Grup | Tarih

Kavram — Prediction ≠ Safety: Yapay zekâ bir karar üretir; güvenliği garanti eden mimari YZ'nin **dışında** tanımlanmalıdır.
Araçlar: fail-safe · human override · monitoring · confidence threshold · fallback.

Kamera → YZ Modeli → OK / RED → Parametre → Robot

Görev — üç başarısızlıkta güvenli davranış

1. **Model yanlış sınıflandırdı:** Kusurlu parçaya OK verdi. Sistem ne yapmalı? İkinci kontrol / insan onayı var mı?

Ölçüm YZ'si tek başına kalınlık kararı vermez. İkinci bağımsız ölçüm (mekanik/lazer) ve örnekleme; kritik ölçü sapmasında insan onayı. Hata oranı eşik üstüne çıkarsa hat durur.

2. **Girdi manipüle edildi:** Kamera verisi bozuk/sahte. Nasıl fark edilir? Şüpheli girdide ne yapılır?

Bütünlük kontrolü (görüntü istatistiği, donmuş kare, zaman kontrolü), sensör öz testi. Şüpheli girdide parça reddedilir, makine durdurulur ve insana bildirilir. 'Geçir' varsayılanı yok.

3. **Confidence düştü:** Model "emin değilim" diyor. Eşik ne olmalı? Altında: dur / insana sor / fallback?

Eşiğin altında otomatik ölçü kabulü yok. Önce insana sorulur; belirsizlik sürerse güvenli varsayılan (dur/ret). Eşik risk değerlendirmesiyle kalibre edilir ve kayda geçer.

Karar tablosu — AI Fail-Safe Decision

Başarısızlık	Tanımladığınız güvenli davranış (hangi kavramla?)
Model yanlış sınıflandırdı	İkinci bağımsız ölçüm + örnekleme + insan onayı (human override, monitoring); eşik aşılırsa fail-safe
Girdi manipüle edildi	Bütünlük kontrolü; şüpheli girdi reddi (fail-safe, monitoring)
Confidence düştü	Confidence threshold altında kabul yok; fallback: insan veya dur

Bu föyün çıktısı **AI Fail-Safe Decision** → Evidence Pack **EP 03 + EP 15** başlığına oturur.